Лабораторная работа № 3 – Изучение экземпляров вредоносного программного обеспечения используемого в целенаправленных атаках

Цель работы

Изучение сценариев известных целенаправленных атак (APT, Advanced persistent threats), рассмотрение способов их обнаружения и предотвращения. Изучение вредоносного программного обеспечения (ВПО), используемого в целенаправленных атаках.

Формулировка задания

В ходе выполнения лабораторной работы необходимо выполнить следующие действия:

1. Получить у преподавателя вариант задания (таблица 1), состоящий из названия группы, реализующей целенаправленные атаки (APT). Получить ссылку на исследуемые файлы, связанные с указанной атакой (при наличии пароля на архиве: infected/malware). В ходе выполнения лабораторной работы необходимо изучить не менее 3 **исполняемых файлов** (.exe, .dll, .sys и т.п.), используемых в указанной APT компании. Вместо указанных по ссылке, по согласованию с преподавателем, могут исследоваться другие вредоносные файлы [8-19], относящиеся к указанной APT-группе.
2. При проведении исследования ОБЯЗАТЕЛЬНО (!) все взаимодействия с изучаемыми файлами проводить в виртуальной машине (ВМ) с отключенными средствами интеграции с хостовой системой, включая разделяемые директории [1]. Не подключайте к ВМ никакие USB-накопители. В случае, если не исследуется сетевое взаимодействие экземпляра следует также отключить сетевой интерфейс в ВМ. При наличии сетевого интерфейса рекомендуется не использовать соединение типа мост (bridge), чтобы исследуемое ПО не имело доступ напрямую в вашу локальную сеть. Особо следует быть осторожным с файлами Microsoft Office, архивами и lnk-файлами. Так как эти средства эксплуатации уязвимостей, которые могут быть запущены

случайно. Рекомендуется создать снимок (snapshot) чистой системы с установленными средствами анализа до начала исследования.

3. Исследовать существующие публикации, описывающие указанную целенаправленную атаку и инструменты, используемые в ней. Представить в отчете описание рассматриваемых атак.

4. Провести предварительный динамический анализ с использованием изолированных сред динамического анализа ВПО (malware sandbox), например, Cuckoo Sandbox [2] / CAPE2 [3], DRAKVUF [4], либо их аналогов в виде онлайн-сервисов [5]. Получить начальную информацию о поведении и назначении исполняемых файлов.

5. Провести углубленный динамический и статический анализ полученных экземпляров ВПО с целью определения наиболее опасных функциональных возможностей в нем. С помощью утилит мониторинга изменений в системе (например, SysTracer, Total Uninstall, Sandboxie, RegShot) отследить изменения в системе после запуска исследуемых файлов (драйверы, службы, реестр, файлы). Используя утилиты ProcessMonitor и WinAPIOverride/WinAPI Monitor отследить действия, выполняемые исследуемым ПО. Используя утилиту ProcessHacker изучить создаваемые ВПО процессы и их ресурсы (загруженные библиотеки, открытые файлы, объекты синхронизации, сетевые порты). Для определения назначения исполняемых файлов и их алгоритмов работы стоит использовать дизассемблеры (IDA Pro/Ghidra) и отладчики (x64dbg/Immunity Debugger/WinDBG) и WinAPI-мониторы (WinAPIOverride, WinAPI Monitor).

6. Описать принцип работы исследованных компонентов. Определить и изучить код, связанный с осуществлением следующих действий, соответствующих классификации MITRE ATT&CK [6]:

a. закрепление в системе (добавление в автозагрузку, заражение существующих файлов, установка своих компонентов, установка служб);

b. повышение привилегий (эксплуатация уязвимостей, запуск специальных инструментов);

c. сбор информации о системе (пользователи, установленное ПО, недавно используемые программы и файлы и т.д.);

d. поиск средств защиты в системе (анализ процессов, файлов/директорий, реестра);

e. сетевая активность (сбор информации об устройстве сети, сетевые атаки);

f. реализация сетевых атак (MITM);

g. эксплуатация уязвимостей (CVE, описание уязвимости);

h. связь с управляющим (C&C) сервером (получение / отправка информации);

i. поиск целевой информации в системе (название и содержание файлов);

j. доступ к критической информации (кража аутентификационной информации: пароли, история браузера и других приложений);

k. реализация вредоносных действий (майнинг, разрушающее воздействие, шифрование);

l. взаимодействие с информацией, хранимой другими приложениями (браузеры, почта);

m. изменение конфигурации системных и прикладных приложений (RDP, межсетевой экран, Windows Defender и т.д.).

7. Привести фрагменты ассемблерного / псевдокода (восстановленного кода на языке C) наиболее важных функций ВПО, выявленных в соответствие с п. 5 задания.

8. Представить результаты изучения, используемого в APT программного обеспечения в формате таблицы 2.

9. Описать в отчете также следующую информацию касательно исследуемой APT-атаки:

a. цели атак;

b. типовые сценарии атаки;

c. описание используемых уязвимостей;

d. описание используемых сторонних средств (например, mimicatz, PSExec и т.д.);

e. техники, используемые для обхода средств защиты и закрепления в системе;

f. другая важная информация.

Список ссылок

1. https://www.malwaretech.com/2017/11/creating-a-simple-free-malware-analysis-environment.html
2. Песочница (malware sandbox) Cuckoo Sandbox https://cuckoosandbox.org/
3. Песочница (malware sandbox) CAPEv2
   https://github.com/kevoreilly/CAPEv2
   https://capesandbox.com/analysis/
4. DRAKVUF https://drakvuf.com
   https://github.com/tklengyel/drakvuf
5. Онлайн-песочницы (malware sandbox)
   https://www.hybrid-analysis.com/
   https://any.run/
   https://www.virustotal.com
6. Michael Sikorski, Andrew Honig. Practical Malware Analysis
   https://doc.lagout.org/security/Malware%20%26%20Forensics/Practical%20Malware%20Analysis.pdf
   https://library.samdu.uz/files/1b7fcd1ad7f0fd6f3ac8a3ffe87166ec_Prakticheskiy_analiz_vrednosnogo_bzd_channel.pdf
7. MITRE ATT&CK https://attack.mitre.org/
8. https://github.com/CyberMonitor/APT_CyberCriminal_Campagin_Collections
9. https://github.com/cyber-research/APTMalware/tree/master/samples
10. https://github.com/Cherishao/APT-Sample
11. http://www.secrepo.com/
12. https://github.com/kbandla/APTnotes
13. https://github.com/blackorbird/APT_REPORT
14. https://github.com/ytisf/theZoo/tree/master/malwares/Binaries
15. https://github.com/StrangerealIntel/CyberThreatIntel
16. https://github.com/abzcoding/aptdetector
17. https://github.com/cyber-research/APTAttribution

18. https://github.com/PaulSec/API-malwr.com
19. https://github.com/sapphirex00/Threat-Hunting

Таблица 1 – Варианты исследуемых целенаправленных атак

Вариант	Название APT	Ссылка на исследуемые файлы
1	Equation Group	https://github.com/cyber-research/APTMalware/tree/master/samples/Equation%20Group
2	Gorgon Group	https://github.com/cyber-research/APTMalware/tree/master/samples/Gorgon%20Group
3	APT 19	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2019
4	APT 28	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2028
5	APT 30	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2030
6	APT 21	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2021
7	APT34	https://github.com/Cherishao/APT-Sample/tree/master/APT34
8	Winnti	https://github.com/cyber-research/APTMalware/tree/master/samples/Winnti
9	APT32	https://github.com/Cherishao/APT-Sample/tree/master/APT32
10	APT 29	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2029
11	EnergeticBear	https://github.com/cyber-research/APTMalware/tree/master/samples/Energetic%20Bear
12	APT 1	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%201
13	APT 10	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2010
14	Stuxnet	https://github.com/Cherishao/APT-Sample/tree/master/Stuxnet%20Malware
15	Dridex	https://github.com/Cherishao/APT-Sample/tree/master/Dridex
16	Turla	https://github.com/Cherishao/APT-Sample/tree/master/Turla
17	DPRK	https://github.com/Cherishao/APT-Sample/tree/master/DPRK
18	Triton	https://github.com/Cherishao/APT-Sample/tree/master/Triton
19	GoziGroup	https://github.com/Cherishao/APT-Sample/tree/master/GoziGroup
20	GreyEnergy	https://github.com/Cherishao/APT-Sample/tree/master/GreyEnergyAPT
21	OlympicDestroyer	https://github.com/Cherishao/APT-Sample/tree/master/OlympicDestroyer
22	DarkHydrus	https://github.com/Cherishao/APT-Sample/tree/master/DarkHydrus
23	Dark Hotel	https://github.com/cyber-research/APTMalware/tree/master/samples/Dark%20Hotel
24	APT 1	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%201
25	APT 19	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2019
26	APT32	https://github.com/Cherishao/APT-Sample/tree/master/APT32
27	APT 10	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2010
28	APT34	https://github.com/Cherishao/APT-Sample/tree/master/APT34
29	APT 30	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2030
30	APT 21	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2021

31	Dridex	https://github.com/Cherishao/APT-Sample/tree/master/Dridex
32	APT34	https://github.com/Cherishao/APT-Sample/tree/master/APT34
33	Turla	https://github.com/Cherishao/APT-Sample/tree/master/Turla
34	APT29	https://github.com/Cherishao/APT-Sample/tree/master/APT29
35	APT34	https://github.com/blackorbird/APT_REPORT/tree/master/APT34
36	Dark Hotel	https://github.com/cyber-research/APTMalware/tree/master/samples/Dark%20Hotel
37	APT30	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2030
38	Equation Group	https://github.com/cyber-research/APTMalware/tree/master/samples/Equation%20Group
39	Gorgon Group	https://github.com/cyber-research/APTMalware/tree/master/samples/Gorgon%20Group
40	APT 19	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2019
41	APT 28	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2028
42	Turla	https://github.com/Cherishao/APT-Sample/tree/master/Turla
43	APT 21	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2021
44	Dark Hotel	https://github.com/cyber-research/APTMalware/tree/master/samples/Dark%20Hotel
45	Winnti	https://github.com/cyber-research/APTMalware/tree/master/samples/Winnti
46	GreyEnergy	https://github.com/Cherishao/APT-Sample/tree/master/GreyEnergyAPT
47	APT28	https://github.com/Cherishao/APT-Sample/tree/master/APT28
48	APT32	https://github.com/Cherishao/APT-Sample/tree/master/APT32
49	APT1	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%201
50	DustSquad	https://github.com/Cherishao/APT-Sample/tree/master/DustSquad
51	APT10	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2010
52	APT28	https://github.com/Cherishao/APT-Sample/tree/master/APT28
53	EnergeticBear	https://github.com/Cherishao/APT-Sample/tree/master/EnergeticBear
54	APT30	https://github.com/cyber-research/APTMalware/tree/master/samples/APT%2030
55	APT28	https://github.com/Cherishao/APT-Sample/tree/master/APT28
56	Stuxnet	https://github.com/Cherishao/APT-Sample/tree/master/Stuxnet%20Malware
57	GamaredonGroup	https://github.com/Cherishao/APT-Sample/tree/master/GamaredonGroup
58	GreyEnergy	https://github.com/Cherishao/APT-Sample/tree/master/GreyEnergyAPT
59	OlympicDestroyer	https://github.com/Cherishao/APT-Sample/tree/master/OlympicDestroyer

Таблица 2 – Результаты изучения компонентов ВПО, используемого в APT

№	Название компонента	Назначение	Вредоносные действия, техники MITRE ATT&CK	Описание и принципы работы	Индикаторы компрометации (IoC)	Способы выявления	Ссылки
1							